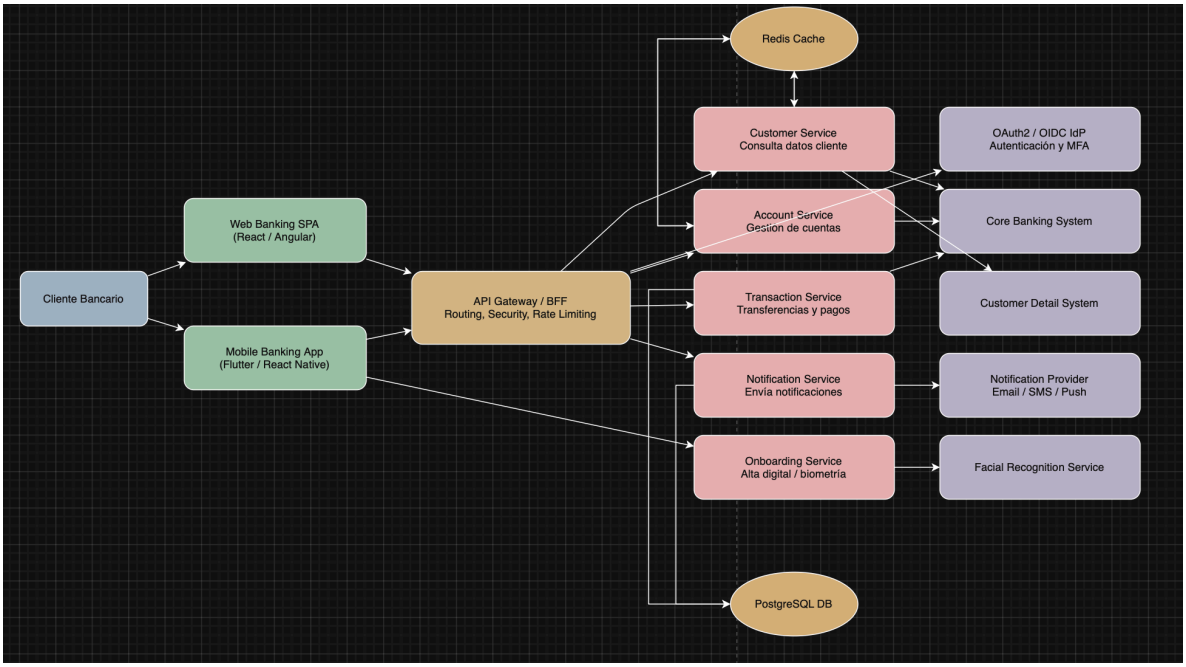
# SOLUCION ARQUITECTONICA PARA BP

## Introducción

El presente documento describe el diseño arquitectónico de un sistema de banca por internet para la entidad BP. La solución permite a los clientes consultar información de sus cuentas, revisar movimientos y realizar transferencias entre cuentas propias e interbancarias. Para representar la arquitectura del sistema se utiliza el modelo C4, el cual permite visualizar el sistema desde diferentes niveles de abstracción: contexto, contenedores y componentes.

El objetivo del diseño es proponer una arquitectura desacoplada, segura y escalable que permita integrar sistemas externos como el Core bancario, sistemas de detalle de cliente, servicios de autenticación y proveedores de notificaciones. Adicionalmente, el diseño considera aspectos importantes para sistemas financieros como alta disponibilidad, seguridad, monitoreo y auditoría.

## Diagrama de contexto




El diagrama de contexto presenta una vista general del sistema de banca por internet y sus principales actores y sistemas externos. Este diagrama permite entender cómo interactúan los usuarios finales con el sistema y qué servicios externos participan en la solución.

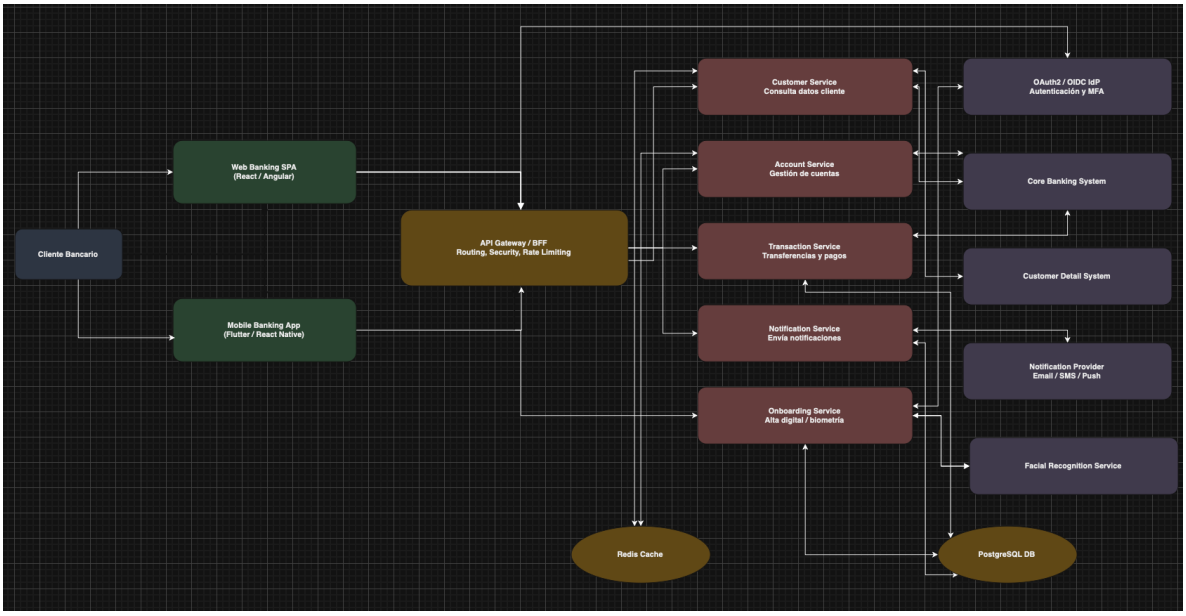
En este nivel se identifican los clientes del banco como los principales usuarios del sistema, quienes acceden a través de dos aplicaciones: una aplicación web y una aplicación móvil.

Ambas aplicaciones permiten consultar movimientos, visualizar productos financieros y realizar transferencias.

El sistema también se integra con sistemas externos relevantes para el negocio. El Core Banking System proporciona información básica del cliente, cuentas y movimientos. Adicionalmente, se utiliza un sistema independiente de detalle de cliente que complementa la información cuando se requiere mayor nivel de detalle.

El sistema de autenticación se delega a un proveedor de identidad basado en el estándar OAuth2/OIDC, lo que permite centralizar la autenticación y reducir la complejidad del sistema principal. Finalmente, el sistema se integra con proveedores de notificaciones externos que permiten enviar alertas al cliente cuando se realizan movimientos en sus cuentas.

## Diagrama de contenedores




El diagrama de contenedores describe la arquitectura del sistema desde una perspectiva técnica, mostrando las principales aplicaciones, servicios y bases de datos que conforman la solución.

El sistema cuenta con dos aplicaciones en el front-end: una aplicación web tipo SPA y una aplicación móvil desarrollada con un framework multiplataforma. Ambas aplicaciones se comunican con la capa de integración mediante un API Gateway, el cual centraliza el acceso a los servicios del sistema.

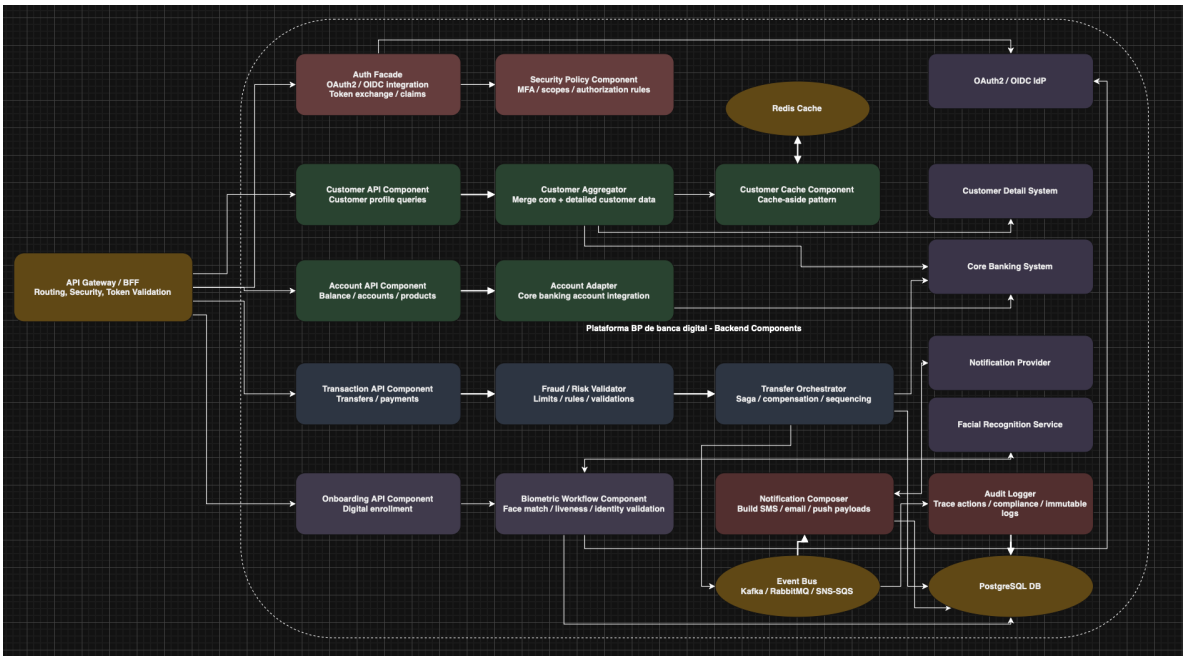
El API Gateway cumple funciones de enrutamiento, seguridad y control de acceso a los diferentes servicios. Desde este punto se enrutan las solicitudes hacia los servicios correspondientes según el tipo de operación solicitada por el usuario.

La arquitectura está compuesta por varios servicios especializados que manejan diferentes responsabilidades. El servicio de clientes se encarga de consultar información básica del cliente, el servicio de cuentas gestiona información relacionada con productos financieros, el servicio de transacciones procesa transferencias y pagos, y el servicio de notificaciones envía alertas a los usuarios cuando se detectan movimientos en sus cuentas.

Adicionalmente, el sistema incluye un servicio de onboarding para el registro de nuevos clientes desde la aplicación móvil, el cual utiliza reconocimiento facial como parte del proceso de validación de identidad.

Para mejorar el rendimiento del sistema se utiliza un mecanismo de caché basado en Redis que permite almacenar información de clientes frecuentes y reducir las consultas repetidas a los sistemas externos. Asimismo, se utiliza una base de datos PostgreSQL para persistencia de información operativa y registro de auditoría.

## Diagrama de componentes




El diagrama de componentes describe con mayor nivel de detalle la estructura interna de los servicios del sistema y la interacción entre los diferentes módulos que componen la solución.

En la capa de integración, el API Gateway actúa como punto único de entrada para las aplicaciones cliente. Este componente se encarga de validar solicitudes, aplicar políticas de seguridad y enrutar las peticiones hacia los servicios correspondientes.

Los servicios de negocio se organizan de manera desacoplada siguiendo el principio de responsabilidad única. El servicio de clientes integra información proveniente del Core bancario y del sistema de detalle de cliente, permitiendo consolidar los datos necesarios para las consultas del usuario. El servicio de cuentas se encarga de gestionar los productos financieros asociados al cliente.

El servicio de transacciones incluye componentes especializados para validar las operaciones antes de enviarlas al Core bancario, garantizando que las transferencias cumplan con las reglas de negocio y controles de seguridad. Una vez procesada la transacción, se generan eventos que permiten activar otros procesos del sistema.

El servicio de notificaciones utiliza estos eventos para generar alertas hacia los clientes mediante proveedores externos de mensajería, como correo electrónico o SMS. De esta manera se garantiza que los usuarios sean informados cuando se realicen movimientos en sus cuentas.

El sistema de onboarding incluye componentes responsables de validar la identidad del usuario mediante reconocimiento facial y registrar la información necesaria para permitir su acceso al sistema.

Finalmente, todos los eventos relevantes del sistema son registrados en un mecanismo de auditoría que permite almacenar las acciones realizadas por los usuarios, cumpliendo con los requisitos de trazabilidad necesarios para sistemas financieros.

## Arquitectura de Autenticación

La autenticación del sistema se basa en el estándar OAuth2 utilizando un proveedor de identidad externo compatible con OpenID Connect. Este enfoque permite delegar la gestión de autenticación y autorización a un sistema especializado, reduciendo la complejidad del sistema principal.

El flujo recomendado para este tipo de aplicaciones es el Authorization Code Flow con PKCE, el cual es ampliamente utilizado para aplicaciones web y móviles. Este flujo permite proteger las credenciales del usuario y evitar ataques de interceptación de tokens.

Al utilizar un proveedor de identidad externo se logra centralizar la gestión de usuarios, mejorar la seguridad del sistema y facilitar la integración con otros sistemas de la organización que requieran autenticación.

## Arquitectura de Onboarding

El proceso de onboarding permite registrar nuevos usuarios desde la aplicación móvil mediante un proceso de verificación de identidad. Este proceso incluye el uso de reconocimiento facial para validar que el usuario corresponde a la identidad registrada.

El servicio de onboarding interactúa con un servicio externo de reconocimiento facial que permite validar la identidad del cliente de forma automática. Una vez verificada la identidad, el usuario puede completar su registro y posteriormente autenticarse utilizando credenciales tradicionales o métodos biométricos.

Este enfoque permite mejorar la seguridad del proceso de registro y reducir el riesgo de suplantación de identidad.

## Arquitectura de auditoría

El sistema incluye un mecanismo de auditoría que registra todas las acciones relevantes realizadas por los usuarios dentro de la plataforma. Esto incluye consultas de información, transferencias realizadas y accesos al sistema.

La información de auditoría se almacena en una base de datos dedicada que permite mantener un historial completo de las operaciones realizadas. Este registro es fundamental para cumplir con los requerimientos regulatorios de las entidades financieras y facilitar procesos de monitoreo y análisis de seguridad.

## Alta disponibilidad y tolerancia a fallos

La arquitectura propuesta considera principios de alta disponibilidad y tolerancia a fallos mediante el uso de servicios desacoplados y escalables. La separación de responsabilidades entre servicios permite que cada componente pueda escalar de manera independiente según la demanda del sistema.

El uso de un API Gateway facilita la gestión centralizada del tráfico hacia los servicios y permite aplicar mecanismos de balanceo de carga y control de acceso. Asimismo, el uso de Redis como mecanismo de caché contribuye a mejorar el rendimiento del sistema y reducir la dependencia de sistemas externos.

## Consideraciones normativas

En el diseño del sistema se consideran aspectos normativos relevantes para entidades financieras, especialmente aquellos relacionados con la protección de datos personales, seguridad de la información y auditoría de operaciones.

El registro de auditoría permite mantener trazabilidad de las acciones realizadas por los usuarios, lo cual es un requisito importante en entornos bancarios. Adicionalmente, el uso de mecanismos de autenticación basados en estándares como OAuth2 contribuye a fortalecer la seguridad del sistema.

## Justificación de decisiones arquitectónicas

### Uso de API Gateway

Se decidió utilizar un API Gateway como punto único de entrada al sistema. Este enfoque permite centralizar funciones como autenticación, control de acceso, rate limiting y enrutamiento de solicitudes hacia los diferentes servicios del sistema.

Una de las principales ventajas de esta arquitectura es la reducción del acoplamiento entre las aplicaciones cliente y los servicios internos. Además, permite implementar políticas de seguridad y monitoreo de forma centralizada, lo cual es especialmente importante en sistemas financieros.

### Uso de arquitectura basada en microservicios

El sistema se diseñó utilizando una arquitectura basada en microservicios para separar responsabilidades funcionales en servicios independientes. Este enfoque permite que cada servicio pueda evolucionar, desplegarse y escalar de manera independiente.

Otra ventaja importante es la mejora en la resiliencia del sistema. En caso de que un servicio presente fallas, los demás servicios pueden seguir operando sin afectar completamente la disponibilidad del sistema.

### Uso de Redis como mecanismo de caché

Redis se utiliza como mecanismo de caché para almacenar información de clientes que es consultada con frecuencia. Esto permite reducir la cantidad de llamadas a sistemas externos como el Core bancario o el sistema de detalle de cliente.

El uso de caché mejora el rendimiento del sistema y reduce la latencia en las respuestas al usuario, lo cual es un factor importante en aplicaciones financieras donde se espera una experiencia rápida y fluida.

### Uso de OAuth2 y OpenID Connect

El sistema utiliza un proveedor de identidad basado en OAuth2 y OpenID Connect para manejar la autenticación de usuarios. Este enfoque permite delegar la gestión de identidad a un sistema especializado, reduciendo la complejidad del sistema principal.

Además, el uso de estándares ampliamente adoptados facilita la integración con aplicaciones web y móviles, y permite implementar flujos de autenticación seguros como Authorization Code Flow con PKCE.